Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each control, including the type and purpose, refer to the control categories document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☑	Least Privilege
☐	☑	Disaster recovery plans
☑	☐	Password policies
☐	☑	Separation of duties
☑	☐	Firewall
☐	☑	Intrusion detection system (IDS)
☐	☑	Backups
☑	☐	Antivirus software
☐	☑	Manual monitoring, maintenance, and intervention for legacy systems
☐	☑	Encryption
☐	☑	Password management system
☑	☐	Locks (offices, storefront, warehouse)
☑	☐	Closed-circuit television (CCTV) surveillance

☑	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each compliance regulation, review the controls, frameworks, and compliance reading.

Then, select "yes" or "no" to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☑	Only authorized users have access to customers' credit card information.
☐	☑	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☑	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☑	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☑	E.U. customers' data is kept private/secured.
☑	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☑	Ensure data is properly classified and inventoried.

☑	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☑	User access policies are established.
☐	☑	Sensitive data (PII/SPII) is confidential/private.
☑	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☑	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

Least privilege is a major security control that will protect against insider threats or the comprimisation of an employee's credential or token. Limiting access of PII and SPII will remove the threat of user data and privacy being tampered or sold. Immediately, remove access to all employees that do not require this information and ensure that only those who absolutely need access to be given. There should be different levels of access within the IAM that require several authentications to receive these authorizations.

Passwords should require atleast 8 characters, 1 special character, and 1 number. Implementing password policies that are stricter create more secure credentials to prevent vulnerabilties. To protect the IT infrastructure, a password manager should be implemented

such as BitWarden or 1Password Business. This would remove the issue of password resets consuming time and effort for the IT department.

A disaster recovery plan is a mitigation strategy that needs to be addressed immediately. Backup servers withholding critical data safeguards any malicious attacks such as ransomware or a virus. In any event that power goes out or hardrive data fails, the disaster recovery plan handles any loss of data.

Data should not be stored without encryption, especially SPII. Credit card information and SSN should be hashed within the system using a high bit encryption algorithm such as AES-256 bit to secure this vulnerability. Data should be backed up as well.

Separation of duties is an administrative control that can be mitigated through hiring new employees that handle different responsibilities. One person in the company should not be handling multiple different work responsibilities like creating payments and receiving payments. One employee handling everything can be a major threat to internal events such as processing payroll payments to themselves.

An Intrusion Detection System (IDS) such as Snort or Suricata should be implemented and configured with rules that pertain to the company's goal of prevention and detection. In the event of an attack, an IDS can detect real time breaches that may compromise data and protection. Suspicious alerts can be directly sent to the cybersecurity team and prevent threats from acting in real-time. A further step can be implementing an Intrusion Prevention System(IPS) that will also prevent suspicious IPs and the majority of alerts that occur by blocking IP addresses that set flags off.

Manual monitoring and maintenance for legacy systems is a major requirement. Legacy systems should be properly updated and patched. If not, then those systems should be wiped and destroyed to prevent access to data. Newer systems should be purchased and maintained as well to prevent exploitation of vulnerabilities.